

MARCO INTEGRATIVO GQM + PRAGMATIC

Metodología Avanzada para Indicadores ENS 2026

INTRODUCCIÓN EJECUTIVA

Este documento presenta una **metodología híbrida integrada** que combina:

1. GQM (Goal-Question-Metric) - Estructura jerárquica de medición
2. PRAGMATIC Criteria - 9 dimensiones de calidad de métricas
3. ENS (Real Decreto 311/2022) - Marco normativo español
4. Contexto Español - Amenazas, recursos, madurez sector

El resultado es un **sistema de indicadores riguroso, práctico y accionable** que garantiza:

- ✓ Alineamiento con objetivos nacionales (Gobierno)
- ✓ Implementabilidad en organizaciones (CISO)
- ✓ Relevancia para decisiones ejecutivas (CFO)
- ✓ Comparabilidad inter-organizacional (Benchmarking)

PARTE I: ARQUITECTURA GQM FUNDAMENTAL

1.1 Niveles GQM Aplicados a ENS

NIVEL CONCEPTUAL (OBJETIVO/GOAL)

- └ Objetivo 1: "Alcanzar postura de ciberseguridad resiliente"
- └ Objetivo 2: "Detectar amenazas en tiempo real (MTTD < 24h)"
- └ Objetivo 3: "Responder incidentes efectivamente (MTTR < 4h críticos)"
- └ Objetivo 4: "Generar cultura seguridad integral (formación 100%)"

↓ DESCOMPOSICIÓN

NIVEL OPERACIONAL (PREGUNTAS)

- └ Para Objetivo 1:
 - └ P1: ¿Tenemos política de seguridad documentada y actualizada?
 - └ P2: ¿Se evalúan riesgos periódicamente?
 - └ P3: ¿Hay CISO con autoridad ejecutiva?
- └ Para Objetivo 2:
 - └ P4: ¿Existe SIEM implementado?
 - └ P5: ¿Se monitorean eventos en tiempo real?
 - └ P6: ¿Cuál es tiempo promedio detección?
- └ Para Objetivo 3:
 - └ P7: ¿Existe procedimiento respuesta documentado?
 - └ P8: ¿Se analiza cada incidente?
 - └ P9: ¿Cuál es tiempo promedio resolución?
- └ Para Objetivo 4:
 - └ P10: ¿Se imparte formación anual obligatoria?
 - └ P11: ¿Cuántos empleados participan?
 - └ P12: ¿Se mide cambio de comportamiento?

↓ CUANTIFICACIÓN

NIVEL CUANTITATIVO (MÉTRICAS)

- └ Métrica 1: $MTTD = (\Sigma(t_{\text{detección}} - t_{\text{ocurrencia}})) / N_{\text{incidentes}}$ [horas]
- └ Métrica 2: $MTTR = (\Sigma(t_{\text{resolución}} - t_{\text{reporte}})) / N_{\text{incidentes}}$ [horas]
- └ Métrica 3: $Tasa_Cobertura_Formación = N_{\text{formados}} / N_{\text{total_empleados}} \times 100$ [%]
- └ Métrica 4: $IGM = \Sigma(puntuación_dominio \times peso_dominio) / \Sigma(pesos)$ [1.0-5.0]
- └ Métrica 5: $ROI_Ciberseguridad = (Beneficios - Costos) / Costos \times 100$ [%]

1.2 Estructura Jerárquica Completa

Nivel 0 (Visión Nacional):

META NACIONAL: "Alcanzar nivel Tier 1 (Role-modelling) en Global Cybersecurity Index, consolidando liderazgo europeo en ciberseguridad"

Nivel 1 (Objetivos ENS):

- Conformidad completa con RD 311/2022
- Transposición exitosa Directiva NIS2
- Reducción incidentes cibernéticos 40% anual
- Formación del 100% empleados sector público

Nivel 2 (Objetivos Organizacionales):

- IGM $\geq 4,0$ (Madurez Avanzada)
- MTDD < 24 horas
- MTTR < 4 horas (sistemas críticos)
- Cero incidentes con exposición datos personales

Nivel 3 (Preguntas Operacionales): [114 preguntas encuesta]

Nivel 4 (Métricas Técnicas): [20-30 KPIs/KRIs cuantificables]

PARTE II: CRITERIOS PRAGMATIC (9 DIMENSIONES)

2.1 Marco PRAGMATIC Explicado

PRAGMATIC es acrónimo de 9 criterios que aseguran que una métrica sea **práctica, útil y accionable** en entornos reales:

#	Criterio	Definición	Pregunta Clave
1	Predictivo	Predice resultados futuros o riesgos	¿Sirve para anticipar problemas?
2	Relevante	Importa a stakeholders y usuarios	¿Importa a decisores clave?
3	Accionable	Inspira decisión/acción inmediata	¿Permite tomar medidas?
4	Genuino	Mide lo que promete medir (validez)	¿Realmente mide lo que dice?
5	Matemático	Cálculo preciso y reproducible	¿Se calcula siempre igual?
6	Accesible	Fácil de obtener/comprender	¿Es fácil de medir/comunicar?
7	Temporal	Datos recientes y oportunos	¿Está siempre actualizado?
8	Independiente	No sesgado por incentivos perversos	¿Es resistente a manipulación?
9	Costoefectivo	ROI positivo en medición/acción	¿Vale la pena medir?

2.2 Ejemplos de Aplicación PRAGMATIC

Ejemplo 1: Métrica MTTD (Tiempo Medio Detección)

PREGUNTA: "¿Cuánto tardan en detectar un incidente desde su ocurrencia?"

MÉTRICA: $MTTD = (\sum[t_{\text{detección}} - t_{\text{ocurrencia}}]) / N_{\text{incidentes}}$

EVALUACIÓN PRAGMATIC (escala 1-5):

- | | |
|---|--|
| 1. PREDICTIVO: 5/5
Sí. MTTD bajo predice mejor control futuro y menor impacto (correlación fuerte). | |
| 2. RELEVANTE: 5/5
Crítico para ejecutivos. Impacta coste, cumplimiento (NIS2 < 24h), reputación. | |
| 3. ACCIONABLE: 4/5
MTTD > 48h → Invertir SIEM (acción clara)
MTTD < 24h → Mantener (acción: mantener) | |
| 4. GENUINO: 5/5
Valida exactamente capacidad detección.
No hay proxy mejor. | |
| 5. MATEMÁTICO: 5/5
Cálculo matemático exacto.
Reproducible 100%. | |
| 6. ACCESIBLE: 3/5
Requiere logs centralizados + análisis.
No trivial obtener datos reales. | |
| 7. TEMPORAL: 5/5
Actualización diaria (cada incidente).
Dashboard en tiempo real posible. | |
| 8. INDEPENDIENTE: 4/5
Riesgo: Falsificar timestamps.
Auditoría externa mitiga sesgo. | |
| 9. COSTOEFFECTIVO: 4/5
SIEM cuesta 60K€, ahorra 144K€/año.
ROI positivo (payback 5 meses). | |
| PUNTUACIÓN PRAGMATIC TOTAL: 40/45 = 88.9% ✓ | |

Interpretación: Métrica **EXCELENTE** para usar.

Ejemplo 2: Métrica "Conformidad ENS (%)"

PREGUNTA: "¿Qué porcentaje de requisitos ENS cumple?"

MÉTRICA: $\text{Conformidad_ENS} = (\text{Requisitos_implementados} / \text{Requisitos_totales}) \times 100$

EVALUACIÓN PRAGMATIC:

1. PREDICTIVO: 3/5
Parcial. Alta conformidad no garantiza seguridad (puede ser cumplimiento formal).
2. RELEVANTE: 5/5
Crítico. Reguladores (AGE, CCN) lo exigen.
3. ACCIONABLE: 2/5
"Conformidad 78%" no dice qué hacer.
Mejor: "Implementar SIEM (P69)" (acción).
4. GENUINO: 3/5
Riesgo: Checklist sin profundidad.
¿Cumple el espíritu del ENS?
5. MATEMÁTICO: 4/5
Conteo simple, pero definición "cumple" puede ser ambigua (sí/no vs. madurez).
6. ACCESIBLE: 4/5
Fácil de comunicar (%).
Audit documental caro pero viable.
7. TEMPORAL: 2/5
Auditoría anual → dato antiguo (12 meses).
Más frecuencia = más caro.
8. INDEPENDIENTE: 2/5
Riesgo alto: Cumplimiento de papeles.
Auditor sesgado (conflicto interés).
9. COSTOEFFECTIVO: 2/5
Auditoría anual = 15-30K€.
ROI bajo (información limitada/acción).

PUNTUACIÓN PRAGMATIC TOTAL: 27/45 = 60% ⚠

Interpretación: Métrica ADECUADA pero DÉBIL para solo.

Recomendación: Combinar con MTTD, IGM, ROI (métricas más pragmáticas).

PARTE III: INTEGRACIÓN GQM + PRAGMATIC

3.1 Matriz de Alineamiento

GQM LEVEL	PRAGMATIC CRITERIA	ENS REQUISITO
Objetivo 1: Postura Resiliente	Relevante (5/5) Predictor (4/5) Accionable (3/5)	Art. 12-16 Marco Organizativo
Objetivo 2: Detección Rápida (MTTD < 24h)	Accionable (5/5) Temporal (5/5) Costoefectivo (4/5)	Art. 26-34 Monitoreo Eventos
Objetivo 3: Respuesta Efectiva (MTTR < 4h)	Predictor (5/5) Genuino (5/5) Costoefectivo (4/5)	Art. 33-34 Respuesta Incidentes
Objetivo 4: Cultura Seguridad (100% formación)	Predictor (5/5) Relevante (4/5) Independiente (3/5)	Art. 27 Capacitación

3.2 Flujo de Decisión GQM + PRAGMATIC

¿NECESITO MEDIR ESTO?

- ¿Alineado a objetivo ENS? (RELEVANCIA)
Sí: Continuar
No: Descartar
- ¿Predice resultados futuros? (PREDICTIVIDAD)
Sí: Métrica "temprana alerta"
No: Métrica "lagging" (revisión histórica)
- ¿Podemos actuar sobre el resultado? (ACCIONABILIDAD)
Sí: KPI (Key Performance Indicator)
No: Información solamente
- ¿Podemos calcularla sin sesgos? (GENUINIDAD)
Sí: Métrica de confianza
No: Requiere validación externa
- ¿El costo de medición < beneficio? (COSTOEFFECTIVIDAD)
Sí: Implementar
No: Simplificar o descartar
- INCLUIR EN SISTEMA INDICADORES

PARTE IV: APLICACIÓN PRÁCTICA A ENS

4.1 Indicadores Maestros (Tier 1)

Los indicadores de **mayor prioridad estratégica** bajo GQM + PRAGMATIC:

Indicador 1: IGM (Índice Gestión Madurez)

OBJETIVO ENS: Art. 32 "Reportar estado anual ciberseguridad"

GQM GOAL: "Alcanzar madurez $\geq 4.0/5.0$ en 24 meses"

PREGUNTA: "¿Cuál es nivel madurez ciberseguridad actual?"

MÉTRICA: $IGM = \frac{\sum(\text{dominio_puntuación} \times \text{peso})}{5.0}$ [1.0-5.0]

PRAGMATIC SCORE: 42/45 (93%) ✓ EXCELENTE

- Predictivo: 5 (predice vulnerabilidad futura)
- Relevante: 5 (crítico ejecutivos)
- Accionable: 4 (señala brechas específicas)
- Genuino: 4 (basado en 114 preguntas rigurosas)
- Matemático: 5 (cálculo preciso)
- Accesible: 4 (requiere 3 horas análisis)
- Temporal: 3 (anual típicamente)
- Independiente: 4 (auditoría externa validar)
- Costoefectivo: 5 (kit descargado, análisis 25 horas)

Indicador 2: MTTD (Mean Time To Detect)

OBJETIVO ENS: Art. 26, 34 "Detección incidentes"

GQM GOAL: "Detectar amenazas en <24 horas"

PREGUNTA: "¿Cuánto tardan en detectar incidentes?"

MÉTRICA: $MTTD = \frac{(\sum[t_{\text{detección}} - t_{\text{ocurrencia}}])}{N}$ [horas]

PRAGMATIC SCORE: 40/45 (89%) ✓ EXCELENTE

- Predictivo: 5 (predice eficacia defensas)
- Relevante: 5 (NIS2 lo exige <24h)
- Accionable: 4 (MTTD alto → invertir SIEM)
- Genuino: 5 (datos de logs)
- Matemático: 5 (cálculo exacto)
- Accesible: 3 (requiere SIEM + análisis)
- Temporal: 5 (actualizado cada incidente)
- Independiente: 4 (timestamps auditables)
- Costoefectivo: 4 (SIEM: 60K€, ahorro 144K€)

Indicador 3: MTTR (Mean Time To Resolve)

OBJETIVO ENS: Art. 33, 34 "Respuesta incidentes"

GQM GOAL: "Resolver incidentes críticos <4h"

PREGUNTA: "¿Cuánto tardan en resolver incidentes?"

MÉTRICA: $MTTR = \frac{(\sum[t_{\text{resolución}} - t_{\text{reporte}}])}{N}$ [horas]

PRAGMATIC SCORE: 38/45 (84%) ✓ BUENO

- Predictivo: 4 (predice impacto negocio)
- Relevante: 5 (crítico para RTO)
- Accionable: 5 (bajo MTTR → acción clara)
- Genuino: 4 (requiere validar "resolución")
- Matemático: 4 (definición ambigua)
- Accesible: 3 (requiere ticketing)
- Temporal: 5 (actualizado continuamente)
- Independiente: 3 (riesgo "false close")
- Costoefectivo: 4 (ticketing: 5K€, beneficio alto)

4.2 Indicadores Secundarios (Tier 2)

Capacitación Cobertura: 85% PRAGMATIC

- └ Predictivo: 5 (predice phishing clicks)
- └ Relevante: 4 (empleados = vectores ataque)
- └ Costoefectivo: 5 (muy barato implementar)

Tasa Incidentes: 72% PRAGMATIC

- └ Predictivo: 3 (alta no predice futura)
- └ Accionable: 2 ("incidentes ↑ 10%" no explica causa)
- └ Independiente: 2 (riesgo de subreporte)

Vulnerabilidades Críticas Abiertas: 79% PRAGMATIC

- └ Predictor: 4 (indica exposición futura)
- └ Accionable: 5 ("críticas abiertas = remedia ahora")
- └ Temporal: 4 (actualizado semanalmente)

ROI Ciberseguridad: 91% PRAGMATIC

- └ Accionable: 5 (justifica inversiones)
- └ Costoefectivo: 5 (cuantifica valor)
- └ Temporal: 4 (proyecciones 3-5 años)

PARTE V: CUADRO COMPARATIVO

5.1 Métricas Débiles vs. Fuertes (Perspective PRAGMATIC)

Métrica Débil (PRAGMATIC <70%)	Métrica Fuerte (PRAGMATIC >85%)	Recomendación
"Tenemos 150 logs/día"	"MTTD promedio 18 horas"	Usa fuerte
"Conformidad ENS 78%"	"IGM 3.47, brecha 0.53 pts"	Usa fuerte
"6 vulnerabilidades críticas"	"6 críticas, 2 remediadas en plazo"	Combina ambas
"Invertimos 150K€/año"	"ROI +150K€ año 2, payback 11 meses"	Usa ROI

CONCLUSIÓN: APLICAR GQM + PRAGMATIC

Ventajas de esta metodología integrada:

- ✓ **Rigor GQM:** Cada métrica vinculada a objetivo nacional
- ✓ **Practicidad PRAGMATIC:** Cada métrica usable en real-world
- ✓ **Alineamiento ENS:** 100% cobertura normativa
- ✓ **Accionabilidad:** Métricas inspiran decisiones inmediatas

Próximo paso: Consultar matriz de evaluación PRAGMATIC completa (documento 2).

Versión: 1.0

Última actualización: 24 enero 2026

Clasificación: Público